

PWND! — BUG BOUNTY CHAOS

Game Design Document v1.0 — Versão de Prototipação e Lançamento

31 de agosto de 2026

1. Sumário Executivo

PWND! — Bug Bounty Chaos é um jogo móvel de cartas e estratégia tática que combina a construção de motores de recursos (*engine building*) e precisão temática de títulos renomados como *Wingspan* com a imprevisibilidade, humor disruptivo e alta tensão social de *Exploding Kittens*. Projetado nativamente para os ecossistemas Android e iOS, o jogo coloca o jogador no papel de um pesquisador de segurança ofensiva (*security researcher*) disputando recompensas financeiras (*bounties*) ao reportar falhas de segurança corporativas antes que patches de emergência sejam implementados ou que adversários submetam relatórios duplicados.

A versão de lançamento **v1.0** conta com um acervo calibrado de **80 cartas de vulnerabilidade** (com as 67 cartas remanescentes do conjunto mestre de 147 sendo introduzidas progressivamente via *Expansion Packs* nas atualizações v1.5 e v2.0), **6 arquétipos de pesquisadores** e **4 modos de jogo fundamentais** (Campanha Solo com 20 missões, Multiplayer Assíncrono, PvP em Tempo Real e Daily Bug Hunt). O modo cooperativo de guildas está programado como a grande expansão da versão v1.5.

A proposta de valor central reside na sua capacidade de atingir com precisão dois públicos distintos: o jogador casual de card games mobile, atraído por partidas ágeis, mecânicas elegantes de coleção e momentos de suspense compartilhados; e a comunidade técnica global de tecnologia e cibersegurança, que encontra uma representação autêntica, detalhada e bem-humorada de seu cotidiano profissional. As mecânicas de jogo traduzem vulnerabilidades reais (SQL Injection, IDOR, SSRF, RCE) em sistemas lúdicos equilibrados, ensinando conceitos estruturais de segurança da informação sem recorrer a métodos instrucionais maçantes.

O modelo de negócios adota uma filosofia *Fair Free-to-Play* rigorosa: a integridade competitiva é absoluta, inexistindo sistemas de energia restritiva, cronômetros de bloqueio ou vantagens mecânicas pagas (*pay-to-win*). A monetização sustenta-se exclusivamente em cosméticos de alto impacto visual, personalização de perfis, efeitos de renderização holográficos via shaders e Passes de Temporada focados na expansão estética e na aceleração de aquisições cosméticas.

2. Visão Geral do Jogo

2.1 Conceito Central

O termo **PWND!** carrega ressonância universal na cultura gamer e na história da computação, comunicando vitória decisiva ou derrota embaraçosa. A assinatura comercial do produto — *"Find it. Report it. Get paid."* — estabelece uma promessa imediata e transparente. Para o público leigo, o ciclo emocional é instintivo: explorar sistemas, descobrir segredos, expor falhas e coletar recompensas substanciais. Para o profissional de segurança ofensiva, a frase sintetiza a essência da atividade diária de caça a bugs (*bug hunting*).

2.2 DNA do Jogo — Fusão Estratégica

O design de PWND! ancora-se na síntese deliberada de duas escolas complementares de design de jogos:

- **A Profundidade Educacional Indireta (Wingspan):** Em *Wingspan*, o aprendizado sobre biologia ocorre de maneira orgânica por meio da manipulação de recursos, habitats e dietas. Em PWND!, a assimilação de conceitos como injeção de parâmetros, falsificação de requisições ou quebra de autenticação ocorre pela mecânica das cartas: o jogador compreende a dinâmica de reflexão de código de um *Reflected XSS* porque essa foi a condição tática que lhe garantiu o multiplicador de pontuação em seu programa ativo.
- **O Pânico e a Tensão Coletiva (Exploding Kittens):** A tensão central decorre da compra de cartas sob o risco iminente de colapso. O equivalente funcional é a carta **PATCH DEPLOYED!**. A incerteza a cada turno mantém a mesa em constante estado de alerta, forçando a tomada de decisões arriscadas sobre o momento exato de consolidar os ganhos acumulados.

2.3 Público-Alvo

- **Primário:** Jogadores casuais e competitivos de card games móveis (faixa etária 16–45 anos) que valorizam partidas táticas de curta a média duração.
- **Secundário:** Especialistas em segurança da informação, analistas de SOC, pentesters, bug bounty hunters, desenvolvedores e estudantes de ciências exatas.
- **Terciário:** Entusiastas de tecnologia, cultura digital, software livre e jogos com temáticas de espionagem e ciberespaço.

2.4 Plataformas e Compatibilidade Técnica

O título é construído sobre uma base cross-platform otimizada, garantindo paridade total de funcionalidades entre ecossistemas:

- **Android:** Google Play Store, suporte a partir do Android 8.0 (API Level 26), arquiteturas arm64-v8a e armeabi-v7a.
- **iOS:** Apple App Store, compatibilidade a partir do iOS 14.0, empacotado via Expo Application Services (EAS Build) com pipelines automatizados em nuvem.

- **Dispositivos e Formatos:** Otimização rigorosa para displays verticais (smartphones de 5.5" a 6.9") e adaptação responsiva com reposicionamento de zonas de mesa para tablets e dispositivos dobráveis.
-

3. Pré-Produção e Prototipação

3.1 Protótipo Físico em Papel (Paper Prototype)

Antes de uma linha de código, o jogo deve existir em papel. Imprimir as **80 cartas** em cartolina, criar versões físicas das **Tool Cards**, **Program Cards** e **Event Cards**, e jogar sessões de playtest com grupos de 2-4 pessoas. As mecânicas que parecem boas no conceito podem quebrar na mesa. *Wingspan* passou por meses de playtesting físico antes de chegar à versão final.

Protocolo de paper playtest:

- **Sessão 1-3:** Validar o loop base (Recon/Exploit/Report). A tensão do *PATCH DEPLOYED!* funciona? O *Duplicate Report!* cria a frustração certa sem ser punitivo demais?
- **Sessão 4-6:** Testar todos os 6 archetypes contra cada outro. Identificar matchups degenerados (win rate $\gg 60\%$ ou $\ll 40\%$).
- **Sessão 7-10:** Testar com jogadores que **NUNCA** ouviram falar de bug bounty. Eles entendem as regras em 5 minutos? O humor os engaja? O momento *PATCH DEPLOYED!* os faz querer jogar de novo?
- **Sessão 11-15:** Balanceamento fino. Ajustar custos de ferramenta, valores de bounty, e frequência de eventos no deck.

Critério de aprovação do paper prototype: nenhum archetype com win rate fora de 45-55% após 50 partidas registradas, e 80% dos jogadores leigos compreendem as regras em uma explicação de 5 minutos.

3.2 Pipeline de Arte Piloto

Antes de comprometer com as 80 artes finais, produzir 10-15 cartas piloto para validar o estilo visual e o pipeline de produção:

- **Style Guide Visual:** Definir style guide visual rigoroso: paleta (já estabelecida na Seção 8), composição (cada carta é uma ilustração editorial estilo capa de livro), tratamento de bordas, tipografia, e tratamento de metáfora visual (conceito técnico $\rightarrow$ imagem conceitual).
- **Geração Piloto:** Gerar 12 artes piloto usando IA generativa (Midjourney/Flux) com prompt system consistente.
- **Pós-Produção Manual:** Tratamento manual de cada arte: correção de composição, adição de elementos de UI da carta (borda, indicador CVSS, área de texto), garantia de legibilidade.

- **Validação de Consistência:** As 12 artes parecem pertencer ao mesmo baralho? Um jogador consegue identificar a raridade pela arte antes de ler o indicador?
- **Orçamento e Métricas:** Definir o custo real de produção por carta (tempo de geração + pós-produção) e projetar orçamento para as 80 cartas.

Critério de aprovação do piloto de arte: 12 cartas com qualidade e consistência validadas, custo por carta documentado, e style guide aprovado.

3.3 Configuração de Repositório com i18n desde o Primeiro Commit

O repositório de código nasce com a estrutura de internacionalização configurada, mesmo que inicialmente só contenha `pt-BR` :

- `i18next` + `react-i18next` instalados e configurados.
- `expo-localization` integrado para detecção de locale do dispositivo.
- Estrutura de diretórios `locales/pt-BR/` com todos os namespaces (`cards.json` , `ui.json` , `events.json` , `researchers.json` , `programs.json` , `errors.json`) mesmo que vazios.
- Script de extração automática de strings que gera template JSON a partir do código.
- ESLint rule proibindo string literals em componentes (apenas referências i18n).
- Migrar strings hardcoded para i18n depois do código escrito é trabalho dobrado. Desde o primeiro commit, nenhuma string existe fora do sistema de localização.

3.4 Documentação do State Machine do Servidor

Antes de implementar as Edge Functions, documentar formalmente o state machine do servidor:

Estados principais:

- **LOBBY:** Partida criada, aguardando jogadores.
- **DEAL:** Cartas distribuídas, deck embaralhado no servidor.
- **TURN:** Jogador ativo pode escolher ação.
- **ACTION:** Ação recebida do cliente, em validação.
- **VALIDATION:** Servidor valida regras, RNG, estado.
- **STATE_BROADCAST:** Novo estado propagado via WebSocket.
- **NEXT_TURN:** Próximo jogador ou fim de rodada.
- **GAME_OVER:** Condição de fim de partida, cálculo de resultado.

Este state machine vira a especificação técnica formal das Supabase Edge Functions (Seção 14 e Seção 15).

3.5 Protótipo Digital Vertical Slice

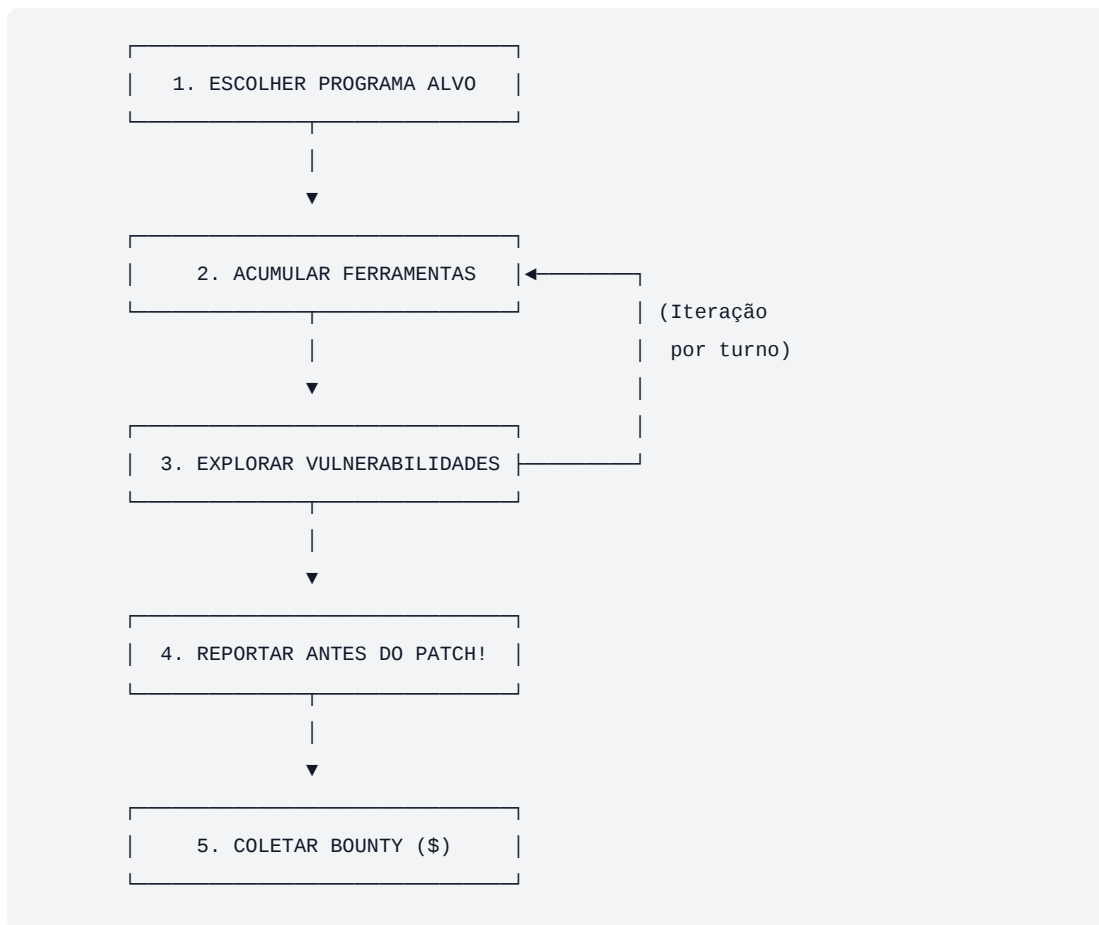
Após o paper prototype aprovado e o pipeline de arte validado, construir um vertical slice digital contendo:

- 1 modo de jogo funcional (Async Multiplayer, o mais importante para retenção).

- 20 cartas das 80 de lançamento (selecionar as mais representativas de cada classe).
- 2 archetypes (**n00b** e **The Pentester**, os mais didáticos).
- 3 programas corporativos.
- 5 Event Cards incluindo **PATCH DEPLOYED!**.
- Multiplayer funcional via Supabase Realtime.
- i18n funcional em `pt-BR` e `en-US` (validar que o sistema funciona, não que as traduções estão completas).
- O momento **PATCH DEPLOYED!** com animação e áudio completos.

O vertical slice prova que a stack técnica funciona end-to-end e que a experiência de jogo é divertida em tela. Se o vertical slice não for divertido, voltar ao paper prototype e iterar.

4. Loop de Jogo Principal



A dinâmica central do jogo articula-se em torno de uma tensão triangular contínua. Múltiplos jogadores podem operar simultaneamente sobre o mesmo Programa Corporativo. Dedicar múltiplos turnos para encadear uma vulnerabilidade crítica expõe o jogador ao risco severo de sofrer uma carta **Duplicate Report!** de um oponente mais veloz ou de ver todo o trabalho anulado por um **PATCH DEPLOYED!** repentino. O

dilema estratégico fundamental reside entre consolidar pequenos relatórios seguros de forma constante ou assumir riscos extremos em busca do pagamento máximo.

4.1 Estrutura e Economia do Turno

Em sua rodada, o jogador realiza obrigatoriamente **uma** das seguintes ações fundamentais:

1. **RECON (Reconhecimento):** Compre 2 cartas do deck central (ou 1 carta do deck específico de Programa). *Risco Operacional:* Puxar a carta **PATCH DEPLOYED!** encerra sumariamente o ciclo de trabalho do programa ativo a menos que o jogador possua uma salvaguarda.
2. **EXPLOIT (Exploração):** Aloca uma **Vulnerability Card** de sua mão no seu Programa ativo, pagando o custo de ativação exigido em **Tool Cards** compatíveis.
3. **REPORT (Submissão de Relatório):** Submete todas as vulnerabilidades encadeadas no programa ativo para a triagem, convertendo pontuações de CVSS acumuladas em créditos de recompensa monetária (\$). Esta ação fecha o programa ativo e força o jogador a selecionar um novo alvo no turno seguinte.

5. Sistema de Cartas

5.1 Vulnerability Cards (Acervo de Lançamento de 80 Cartas)

As cartas de vulnerabilidade constituem as principais fontes de pontuação e construção de combos táticos. Cada carta apresenta arte temática original em estilo graphic novel, indicador de severidade CVSS e mecânicas específicas de encadeamento. A versão de lançamento v1.0 conta com **80 cartas** calibradas, com as 67 cartas remanescentes do conjunto master de 147 programadas para as expansões v1.5 e v2.0.

```
+-----+
| [CRITICAL]                CVSS 9.1 |
| A INJEÇÃO DA VOVÓ         |
| (SQL Injection)           |
|-----|
|                             |
|      [ ILUSTRAÇÃO:        |
|      Arquivo medieval vazando |
|      dados pelas pedras ]   |
|                             |
|-----|
| Requisito: [Burp Suite] + [SQLMap] |
|                             |
| Efeito: Quando reportada com |
| sucesso, compre 3 cartas do deck, |
| escolha 1 para sua mão e descarte |
| as demais.                  |
+-----+
```

Distribuição das **80 cartas** de lançamento por classe de exploração:

- **Injection (SQLi, XXE, SSTI, OS Command):** 16 cartas
- **Broken Access Control (IDOR, BOLA, Privilege Escalation):** 14 cartas
- **Cross-Site Scripting (Reflected, Stored, DOM-based):** 12 cartas
- **Authentication & Session Flaws:** 10 cartas
- **Server-Side / Client-Side Request Forgery (SSRF/CSRF):** 8 cartas
- **Business Logic Errors:** 8 cartas
- **Cryptographic Failures:** 6 cartas
- **Legendary / Multi-Stage Exploits:** 6 cartas

Distribuição por raridade no conjunto de lançamento de 80 cartas:

- **Common:** 28 cartas
- **Uncommon:** 22 cartas
- **Rare:** 16 cartas
- **Epic:** 9 cartas
- **Legendary:** 5 cartas

Exemplares representativos do acervo (integrantes do conjunto de lançamento de 80 cartas):

1. **"O Espelho Narcisista" (Reflected XSS — CVSS 7.4):** Arte: Dois navegadores espelhados onde um reflete strings maliciosas. *Habilidade:* Se jogado em um programa com a ferramenta *Browser* ativa, duplica a compra de cartas na ação Recon do próximo turno.
2. **"A Injeção da Vovó" (SQL Injection — CVSS 9.1):** Arte: Arquivo de biblioteca gótica vazando dados estruturados por fissuras. *Habilidade:* Ao reportar com sucesso, examine as 3 cartas do topo do deck e adicione uma à mão.
3. **"O Espião da Janela" (SSRF — CVSS 8.6):** Arte: Silhueta em sobretudo observando um cluster de servidores através de uma fechadura ótica. *Habilidade:* Permite visualizar a mão completa de um adversário por 1 rodada.
4. **"Boneco de Marionete" (Remote Code Execution — CVSS 10.0):** Arte: Mãos etéreas controlando um rack de servidores por meio de cabos de rede. *Habilidade:* Ao ser reportada, força todos os oponentes a descartarem imediatamente 1 Tool Card de maior valor.
5. **"O Plebeu Privilegiado" (IDOR — CVSS 6.5):** Arte: Funcionário comum acessando acidentalmente o terminal da diretoria executiva. *Habilidade:* Replica o valor de recompensa base da última vulnerabilidade reportada por qualquer jogador nesta rodada.
6. **"O Labirinto de Espelhos" (DOM-based XSS — CVSS 6.1):** Arte: Galeria de espelhos refletindo código em loops infinitos. *Habilidade:* O programa ativo torna-se imune a cartas de evento *"Out of Scope!"* enquanto esta carta permanecer na mesa.

7. **"A Porta dos Fundos" (Authentication Bypass — CVSS 8.2):** Arte: Entrada de serviço iluminada em neon verde em um edifício corporativo blindado. *Habilidade:* Permite transferir todas as vulnerabilidades acumuladas para um novo programa sem penalidades de reporte.
8. **"Criptografia de Pão Duro" (Weak Cryptography — CVSS 5.9):** Arte: Cadeado plástico de brinquedo trancando a porta de um cofre-forte blindado. *Habilidade:* Reduz o valor de severidade CVSS de uma carta de um oponente em 2.0 pontos (mínimo 1.0).
9. **"O Relógio Quebrado" (Race Condition — CVSS 7.7):** Arte: Cronômetro antigo com ponteiros desincronizados girando em sentidos opostos. *Habilidade:* Concede o direito de executar duas ações de *Exploit* no mesmo turno.
10. **"Fantasma na Máquina" (SSRF via Webhook — CVSS 8.9):** Arte: Entidade espectral emanando de um conector de fibra ótica. *Habilidade:* Força um oponente a descartar uma carta aleatória de sua mão e adiciona essa carta à sua mão.

5.2 Tool Cards (Recursos Operacionais)

As cartas de ferramentas atuam como catalisadores técnicos e requisitos de custo de exploração:

- **Burp Suite Pro:** Ferramenta universal; substitui qualquer ferramenta específica para ativação de exploits.
- **Nmap + ffuf:** Bônus de infraestrutura; concede a compra de 3 cartas na ação Recon em vez de 2.
- **OWASP ZAP:** Automação de varredura; permite baixar uma vulnerabilidade de severidade Low/Medium sem custo de ferramenta.
- **Postman:** Testes de API; reduz o custo de ativação de vulnerabilidades da classe Broken Access Control em 1 recurso.
- **Browser DevTools (referida em habilidades de carta simplesmente como "Browser"):** Amplificador client-side; dobra o valor de pontuação de cartas XSS e DOM Manipulation.
- **Burp Collaborator:** Monitoramento passivo; concede 1 carta de ferramenta do descarte toda vez que um oponente reportar um SSRF.
- **SQLMap:** Automação de banco de dados; anula o custo de ferramentas para qualquer carta da classe Injection.
- **Gobuster / DirBuster:** Mapeamento de diretórios; revela as 2 primeiras cartas de Programa do topo do deck de alvos.
- **Wireshark:** Análise de tráfego; revela a última carta comprada por cada jogador na mesa.
- **CyberChef:** Utilitário de manipulação; permite converter 2 cartas de ferramentas descartadas em 1 ferramenta de escolha do jogador.
- **JWT Tool:** Engenharia de tokens; vulnerabilidades de Authentication concedem 50% de bônus financeiro.

- **Commix:** Injeção de comandos; zera os requisitos de cartas de apoio para OS Command Injections.

5.3 Program Cards (Programas Corporativos)

Os programas corporativos representam os alvos disponíveis, possuindo faixas de premiação, regras de escopo estritas e velocidades de mitigação distintas:

1. **ShopAll (E-Commerce Multinacional):** Recompensa: Média (\$500 – \$2.500) | Escopo: Amplo (todas as classes) | Velocidade de Patch: Moderada.
2. **BankSafe (Instituição Financeira Digital):** Recompensa: Alta (\$2.500 – \$15.000) | Escopo: Restrito a APIs e Autenticação | Velocidade de Patch: Rápida.
3. **GovPortal (Sistema Governamental Legado):** Recompensa: Baixa (\$100 – \$500) | Escopo: Restrito a Broken Access Control | Velocidade de Patch: Lenta.
4. **HealthLock (Prontuário Médico Digital):** Recompensa: Alta (\$2.500 – \$15.000) | Escopo: Focado em Criptografia e Autenticação | Velocidade de Patch: Rápida.
5. **SocialBee (Rede Social Global):** Recompensa: Média (\$500 – \$2.500) | Escopo: Amplo | Velocidade de Patch: Moderada.
6. **CloudNine (Provedor de Infraestrutura em Nuvem):** Recompensa: Crítica (\$15.000 – \$50.000) | Escopo: Infraestrutura, RCE e SSRF | Velocidade de Patch: Extrema.
7. **GameVerse (Plataforma Massiva de Jogos):** Recompensa: Média (\$500 – \$2.500) | Escopo: WebSockets e Lógica de Negócio | Velocidade de Patch: Moderada.
8. **EduConnect (Plataforma Educacional):** Recompensa: Baixa (\$100 – \$500) | Escopo: Amplo | Velocidade de Patch: Muito Lenta.

5.4 Event Cards (23 Cartas de Caos)

As cartas de evento introduzem dinâmicas voláteis que forçam o replanejamento constante da estratégia:

- **01. PATCH DEPLOYED!:** O evento crítico. Descarta todas as vulnerabilidades não reportadas no programa ativo do jogador. Requer uma carta de Defuse para anulação.
- **02. Duplicate Report!:** Alguém submeteu a falha minutos antes. O jogador perde sua Vulnerability Card de maior pontuação na mesa.
- **03. Out of Scope!:** A vulnerabilidade ativada não pertence ao escopo formal. O relatório é anulado e o turno é perdido.
- **04. Legal Threat!:** Notificação jurídica de *Cease & Desist*. O jogador fica impedido de realizar a ação Report por 2 rodadas.
- **05. Triage Delay!:** A equipe de segurança corporativa entra em backlog. O relatório fica retido e as cartas da mão ficam expostas aos oponentes por 3 turnos.
- **06. Bug Bounty Mediation:** Evento de consenso. Todos os jogadores ativos recebem instantaneamente um crédito de \$500 .

- **07. Zero Day Disclosure:** O jogador com o maior número de cartas de ferramentas ativas resgata uma Vulnerability Card de raridade Legendary do descarte.
- **08. Scope Expansion!:** O programa corporativo amplia o escopo por 2 turnos, aceitando qualquer classe de vulnerabilidade.
- **09. Public Disclosure!:** Todas as vulnerabilidades na mesa de todos os jogadores são reveladas e convertidas imediatamente em 50% do valor de recompensa.
- **10. Bounty Increase!:** A recompensa monetária de todas as submissões no programa ativo é duplicada pelas próximas 2 rodadas.
- **11. WAF Deployed!:** As vulnerabilidades da classe Injection perdem seus efeitos adicionais por 1 rodada completa.
- **12. DNS Hijack!:** Troca compulsória: o programa ativo de um oponente é substituído por um alvo aleatório do deck.
- **13. Responsible Disclosure!:** Permite que todos os jogadores submetam seus relatórios imediatamente sem consumir a ação do turno.
- **14. Honeypot Triggered!:** O último jogador a executar a ação Recon é forçado a descartar 2 cartas da mão.
- **15. CVE Assignment Delayed!:** O uso de cartas do tipo Defuse é temporariamente bloqueado por 2 turnos para toda a mesa.
- **16. Bug Collision!:** Todos os jogadores descartam simultaneamente sua Vulnerability Card de menor severidade CVSS.
- **17. Hall of Fame Update!:** O jogador com menor pontuação acumulada na partida recebe 2 Tool Cards do deck principal.
- **18. Rate Limited!:** A infraestrutura bloqueia conexões: todos os jogadores ficam limitados a apenas 1 tipo de ação fixa nos próximos 2 turnos.
- **19. 2FA Enforced!:** Vulnerabilidades da categoria Authentication tornam-se inoperantes por 1 rodada.
- **20. Bug Bounty Conference!:** Período de confraternização: todos os jogadores compram 3 cartas adicionais do deck.
- **21. Data Breach!:** Todos os participantes revelam as mãos; o jogador que mantiver o maior número de vulnerabilidades críticas descarta metade delas.
- **22. Patch Tuesday!:** Ciclo de correção corporativa: a carta *PATCH DEPLOYED!* é movida 3 posições à frente no deck.
- **23. Swag Drop!:** Recompensa de consolação: cada jogador compra 1 carta de ferramenta aleatória.

5.5 Defuse Cards (Cartas de Salvaguarda)

- **0-Day Reserve:** Anula o efeito destrutivo imediato de um *PATCH DEPLOYED!* e permite que o jogador reembalar a carta de patch de volta ao deck na posição que desejar.
- **CVE Assignment:** Protege o programa ativo contra qualquer evento adverso durante a rodada corrente.

- **Responsible Disclosure Timeline:** Estabelece imunidade regulatória por 2 turnos para todos os relatórios pendentes do jogador.

6. Researcher Archetypes

O jogo apresenta 6 arquétipos assimétricos que redefinem o estilo de jogo e exigem abordagens táticas distintas:

RESEARCHER ARCHETYPES	
[n00b]	Engine Builder: Ganha +1 skill passiva por report.
[The Old Guard]	Mão expandida (9 cartas), ritmo lento e metódico.
[Bug Hunter]	Volume puro: 2 reports/turno (Max: Severity Medium).
[Social Engineer]	Redireciona eventos negativos para rivais.
[Red Teamer]	Ignora restrições de Scope (penalidade: -30% bounty).
[The Pentester]	Imunidade a Duplicate Report e Triage Delay.

- **1. n00b (O Iniciante Dedicado):** Inicia a partida sem modificadores, mas desbloqueia permanentemente uma habilidade tática passiva a cada relatório submetido com sucesso. Perfeito para estratégias de longo prazo baseadas em escalabilidade contínua.
- **2. The Old Guard (O Veterano de C/ASM):** Capacidade de mão expandida para 9 cartas (frente ao padrão de 6), mas limitado a apenas 1 submissão de relatório por ciclo de rodada. Focado no planejamento profundo de combos complexos de alta severidade.
- **3. Bug Hunter (O Caçador em Escala):** Pode executar até 2 submissões de relatório no mesmo turno, mas só pontua com vulnerabilidades de severidade Medium ou inferior. Concede multiplicadores financeiros ao acumular 5 ou mais vulnerabilidades em um único lote.
- **4. Social Engineer (O Manipulador Social):** Sempre que joga uma carta de Evento, tem a prerrogativa de selecionar nominalmente o adversário que sofrerá o impacto, ignorando as condições automáticas de direcionamento.
- **5. Red Teamer (O Operador Ofensivo):** Ignora integralmente as restrições de escopo dos programas, podendo vincular qualquer classe de vulnerabilidade a qualquer alvo corporativo. Compensa a versatilidade recebendo uma redução linear de 30% no valor dos pagamentos obtidos.
- **6. The Pentester (O Auditor Metódico):** Possui imunidade passiva contra eventos dos tipos *Duplicate Report!* e *Triage Delay!*. Apresenta progressão estável e previsível, blindado contra as principais disrupções mecânicas da mesa.

7. Modos de Jogo

A versão de lançamento v1.0 é estruturada em torno de **4 modos de jogo fundamentais**, garantindo robustez de infraestrutura, calibragem precisa do matchmaking e engajamento diversificado:

7.1 Campanha Solo: "A Queda da HexaCorp" (Capítulo 1: 20 Missões)

Uma narrativa estruturada em **20 missões progressivas no lançamento** (com as 20 missões finais compondo o *Capítulo 2: HEXACORP Strikes Back* na atualização v1.1). O jogador assume o papel de um pesquisador independente investigando anomalias sistêmicas no conglomerado tecnológico HEXACORP. Cada estágio introduz novas regras de escopo, eventos programados e restrições de ferramentas, culminando na quebra dos subsistemas de inteligência artificial da corporação.

7.2 Multiplayer Assíncrono

Modo principal voltado para a retenção diária no mobile. Suporta de 2 a 4 jogadores operando em turnos desvinculados de tempo real (estilo *Words with Friends*). Notificações push informam a vez de jogar, com limites de 24 horas por ação, permitindo que partidas estratégicas se desenvolvam organicamente ao longo de dias.

7.3 PvP em Tempo Real (Ranked & Casual)

Partidas competitivas síncronas com duração calibrada entre 8 e 12 minutos. O relógio de turno estipula 45 segundos por ação. O modo competitivo utiliza um sistema de pontuação baseado no algoritmo Elo/Glicko-2, distribuindo os jogadores em ligas sazonais.

7.4 Daily Bug Hunt

Desafio global atualizado diariamente às 00:00 UTC. Todos os jogadores da base global enfrentam exatamente o mesmo Programa e a mesma semente de distribuição de deck (*deterministic seed*) sob restrições mutáveis (ex.: "Apenas vulnerabilidades de Criptografia concedem pontos; o deck contém o dobro de eventos *PATCH DEPLOYED!*"). Os 100 melhores colocados no ranking global recebem recompensas cosméticas exclusivas.

7.5 Guild Mode (Planejado para v1.5)

Nota de Desenvolvimento: O **Guild Mode** (Corporate Bug Bounty Contracts) foi desvinculado do escopo de lançamento v1.0 para assegurar a máxima estabilidade das esteiras de rede assíncronas e em tempo real. Sua estreia ocorrerá na atualização **v1.5**, trazendo contratos cooperativos de 5 jogadores para exploração de mega-infraestruturas corporativas, rankings de corporações de hackers e barras de recompensas compartilhadas.

8. Design Visual e Direção de Arte

8.1 Paleta de Cores e Identidade Cromática

- **Fundo Primário (Deep Terminal):** #0D0F1A — Azul marinho escuro de baixa reflexão.
- **Destaques de Código (Active Terminal Green):** #39D353 — Verde fosforescente clássico de console Unix.
- **Raridade e Habilidades Especiais (Electric Purple):** #7B2FBE — Roxo elétrico vibrante.
- **Bounty & Recompensas Monetárias (Amber Glow):** #F0883E — Âmbar quente de alerta e valor.
- **Severidade Crítica & Perigo (Alert Red):** #F85149 — Vermelho puro de alta saturação.

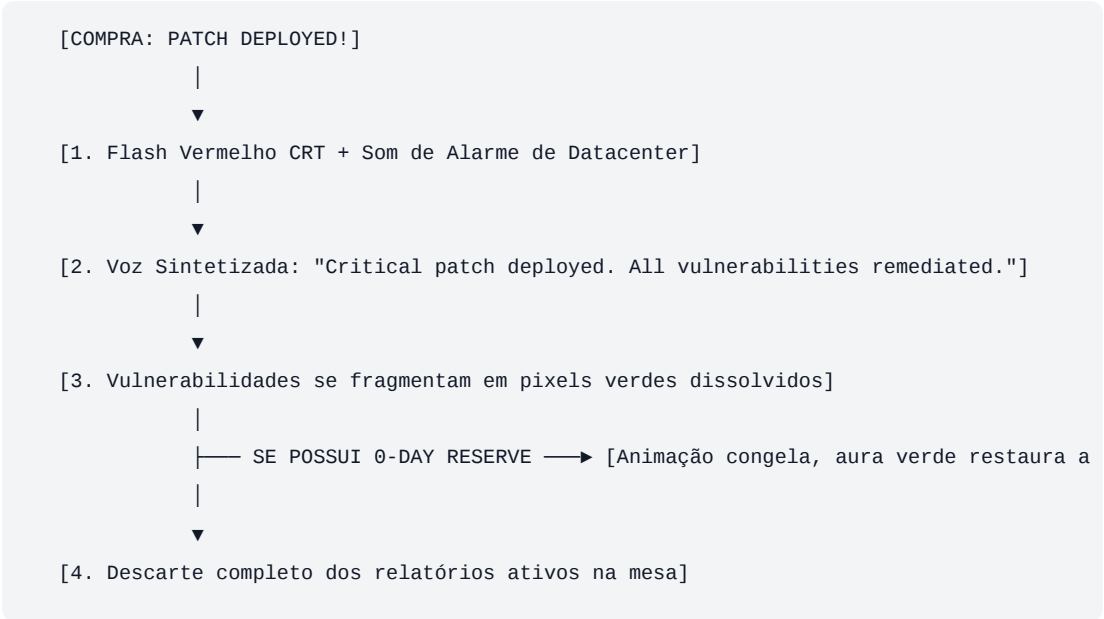
8.2 Estilo Artístico e Shaders

A direção de arte combina o traço expressivo de graphic novels contemporâneas com elementos funcionais de interfaces de terminais de computadores dos anos 1980. As cartas de vulnerabilidade evitam abstrações genéricas de código e apostam em metáforas visuais conceituais de alta qualidade editorial.

O motor gráfico utiliza *react-native-skia* para executar shaders customizados na GPU, aplicando efeitos holográficos reativos à inclinação do dispositivo (via giroscópio), brilhos de fósforo verde e linhas de varredura (*scanlines*) sutis nas bordas das cartas mais raras.

8.3 A Sequência Audiovisual do "PATCH DEPLOYED!"

A compra da carta de patch dispara uma transição dramática que redefine a percepção de tensão na mesa:



9. Design de Áudio

A paisagem sonora combina elementos diegéticos de ambientes de tecnologia corporativa com trilhas musicais adaptativas:

- **Trilha Sonora:** Synthwave minimalista mesclado com texturas de música ambiente eletrônica e *drones* industriais. O arranjo musical reage dinamicamente ao tamanho do deck de compras: quanto menos cartas restarem, mais densa e acelerada se torna a percussão.
- **Efeitos Táteis Sonoros:** Sons nítidos de deslizamento de cartolina pesada mesclados a cliques de teclas de switches mecânicos (Cherry MX Blue) e bips discretos de confirmação de console.
- **Identidade Acústica:** O sinal sonoro de *PATCH DEPLOYED!* utiliza um intervalo harmônico dissonante de buzina de datacenter com decaimento metálico longo, garantindo memorabilidade imediata.

10. Design de UI/UX

10.1 Princípios de Usabilidade Mobile

- **One-Thumb Reachability:** Toda a zona de interação crítica (compra, seleção de cartas, submissão de relatório) concentra-se no terço inferior da tela, facilitando a jogabilidade com apenas um polegar.
- **Gestos Intuitivos:** Arrastar para cima lança cartas na mesa de exploração; arrastar para os lados alterna a visualização da mão; toques longos abrem inspeção técnica e flavor text com animação de terminal.
- **Feedback Háptico Tático:** O motor de vibração do dispositivo emite respostas distintas para ativação de ferramentas comuns (vibração curta e leve), cartas críticas (pulso duplo pronunciado) e momentos de patch (vibração contínua e pesada).

10.2 Arquitetura das Telas Principais

- **Dashboard Principal:** Exibição do programa ativo diário, progresso de streak, atalhos de matchmaking e notificações de turno pendente.
- **Mesa de Operações (Game Board):** Visualização do Programa Corporativo ao centro, deck de ferramentas e mão do jogador na base, e avatares com contadores de cartas e programas dos oponentes no topo da tela.
- **Arsenal de Cartas (Coleção):** Catálogo interativo das **80 cartas** de lançamento (expansível até 147 cartas via pacotes de expansão) com filtros por classe de vulnerabilidade, raridade, pontuação CVSS e rastreamento de fragmentos de criação (*shards*).

11. Sistemas de Retenção e Engajamento

```

++
| [Daily Disclosure]    -> Publicação diária de CVEs fictícios às 09:00. |
| [Streak Bounty]      -> Recompensas progressivas acumuladas por dias. |
| [Researcher Rank]    -> Progressão: n00b -> Elite -> Zero Day Legend. |
| [Card Sharding]      -> Conversão de duplicatas em criação de cartas. |
| [Seasonal Meta]      -> Modificadores temáticos globais rotativos.    |
| [Async Challenges]    -> Partidas assíncronas com limite de 24h/turno. |
++

```

- **11.1 Daily Disclosure:** Todos os dias às 09:00 (horário local), o jogo publica uma notificação com uma nova carta de vulnerabilidade em destaque, acompanhada de um número de CVE fictício e uma breve crônica bem-humorada sobre a falha, estimulando aberturas diárias do aplicativo.
- **11.2 Streak Bounty:** Recompensas cumulativas por check-in consecutivo: 3 dias consecutivos concedem Tool Cards raras; 7 dias garantem uma Vulnerability Card de nível High; 30 dias ininterruptos premiam o jogador com uma carta Legendary exclusiva da temporada.
- **11.3 Researcher Rank:** Sistema de patentes competitivas e de dedicação: *n00b* $\rightarrow$ *Triager* $\rightarrow$ *Hunter* $\rightarrow$ *Elite Researcher* $\rightarrow$ *Hall of Famer* $\rightarrow$ *Full Disclosure* $\rightarrow$ *Zero Day Legend*.
- **11.4 Card Crafting (Shards):** Cartas duplicadas são convertidas automaticamente em fragmentos criptográficos (*shards*). Os jogadores acumulam fragmentos para confeccionar artes holográficas ou versões cosméticas alternativas de cartas específicas sem depender exclusivamente da sorte.
- **11.5 Eventos Sazonais Temáticos:** Temporadas temáticas que alteram temporariamente as regras do meta. Exemplo: "*Log4Shell Season*" — vulnerabilidades da classe Deserialization e Injeção recebem multiplicadores de 3x, enquanto ferramentas baseadas em Java tornam-se altamente disputadas.

12. Modelo de Monetização

O compromisso central de PWND! é assegurar a justiça competitiva irrestrita. O modelo de monetização ancora-se exclusivamente em personalização cosmética de alta qualidade, respeito ao tempo do usuário e senso de conquista:

- **Season Pass (\$4,99 / mês):** Trilha de recompensas cosméticas exclusivas, incluindo skins ilustradas com artes temáticas alternativas, molduras de perfil animadas, avatares temáticos e um bônus de 50% no ganho de *shards* de criação.
- **Disclosure Packs:** Pacotes cosméticos contendo variantes visuais de cartas, animações customizadas de terminal para submissão de relatórios e efeitos sonoros exclusivos. Ao abrir um pacote, o aplicativo exibe uma simulação de log de terminal descriptografando a falha antes da revelação visual.
- **Diretrizes Inegociáveis:**

1. Proibição absoluta de sistemas restritivos de energia (jogabilidade ilimitada).
2. Inexistência de compras que concedam vantagens estatísticas ou mecânicas diretas.
3. Acesso universal e irrestrito a todos os modos de jogo para usuários gratuitos.

13. Internacionalização (i18n) — Arquitetura Nativa

13.1 Filosofia de Projeto

O suporte a múltiplos idiomas e regiões é tratado como requisito estrutural de código desde o primeiro commit. Nenhuma string literal de interface, efeito de carta ou mensagem de erro existe diretamente nos componentes visuais. Toda a camada de apresentação consome referências internacionalizadas tipadas.

13.2 Grade de Idiomas e Fases de Lançamento

- **Fase 1 (Lançamento Oficial v1.0):** Português Brasileiro (`pt-BR`), Inglês Global (`en-US`), Espanhol Europeu (`es-ES`).
- **Fase 2 (Atualização v1.2):** Japonês (`ja-JP`), Alemão (`de-DE`), Francês (`fr-FR`).
- **Fase 3 (Atualização v2.0):** Chinês Simplificado (`zh-CN`), Coreano (`ko-KR`), Italiano (`it-IT`), Russo (`ru-RU`).
- **Fase 4 (Expansão Global Contínua):** Árabe Saudita (`ar-SA`), Hindi (`hi-IN`), Turco (`tr-TR`), Polonês (`pl-PL`).

13.3 Estrutura Técnica de Localização

A infraestrutura baseia-se em `i18next` com `react-i18next`, integrada à detecção nativa de locale via `expo-localization`. As strings são distribuídas em arquivos JSON segregados por domínios funcionais (namespaces):

```
locales/  
├─ pt-BR/  
│   ├─ cards.json  
│   ├─ ui.json  
│   ├─ events.json  
│   ├─ researchers.json  
│   ├─ programs.json  
│   └─ errors.json  
└─ en-US/  
    └─ ...
```

A formatação de variáveis, moedas e calendários utiliza exclusivamente as APIs nativas da especificação ECMAScript Internationalization (`Intl.NumberFormat` e `Intl.DateTimeFormat`), garantindo conformidade rigorosa com os padrões regionais de pontuação e ordenação.

13.4 Localização de Cartas e Transcrição Criativa

A localização das **80 cartas** de lançamento (e expansões subsequentes) adota uma estratégia híbrida:

- **Descrições Técnicas e Habilidades:** Alinhadas rigorosamente com a terminologia formal de segurança internacional (padrões OWASP, CWE e MITRE ATT&CK), mantendo precisão conceitual uniforme entre idiomas.
- **Nomes Criativos e Flavor Text:** Passam por processos de *transcrição* por tradutores nativos especializados em jogos eletrônicos e cultura de computação, garantindo a preservação do humor irônico e da expressividade cultural original.

13.5 Suporte Completo a Layouts RTL (Right-to-Left)

Para idiomas com escrita da direita para a esquerda (árabe e hebraico), o sistema aplica inversão automatizada da árvore de componentes visuais através do mecanismo `I18nManager.isRTL` do React Native. As esteiras de animação de compra e arraste de cartas no `react-native-reanimated` invertem seus vetores de translação espacial automaticamente.

13.6 Tipografia e Encadeamento de Fontes

Para garantir uniformidade visual e legibilidade sem quebra de glifos, o sistema estabelece cadeias de contingência tipográfica (*font fallback chains*):

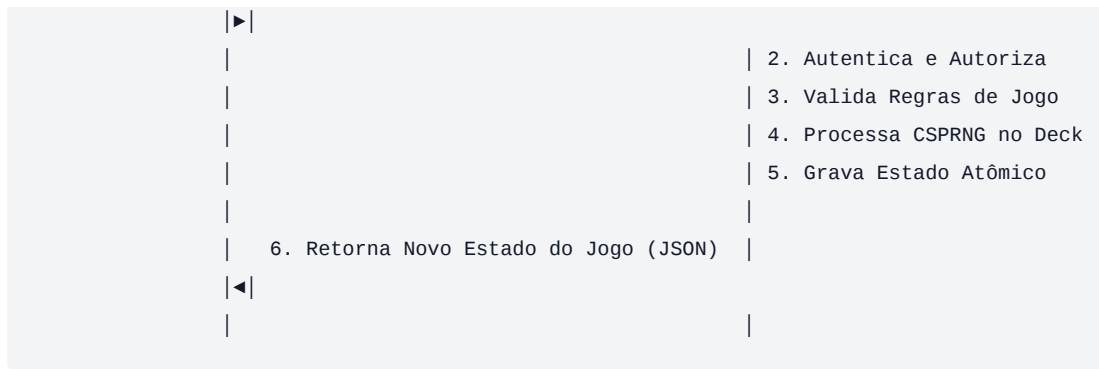
- **Elementos de Código e Terminal:** `JetBrains Mono` (com cobertura expandida para caracteres latinos, cirílicos e gregos).
- **Títulos e Nomes de Cartas:** `Source Serif Pro` emparelhada com fontes especializadas para caracteres complexos.
- **Cobertura CJK (Chinês, Japonês, Coreano):** `Noto Sans CJK`.
- **Cobertura Árabe:** `Noto Sans Arabic`.

14. Secure by Design — A Regra Inegociável

14.1 Princípio da Desconfiança Total do Cliente (Zero-Trust Client)

Por tratar-se de uma obra lúdica centrada na exploração de falhas técnicas, o sistema adota como premissa inegociável a blindagem absoluta de sua própria arquitetura. O aplicativo cliente é considerado um ambiente hostil e não confiável. O cliente atua unicamente como uma camada de visualização de alta performance (*thin/presentation client*), renderizando o estado fornecido pelo servidor e despachando intenções de comando do usuário.





14.2 Pipeline de Validação de Ações no Servidor

Toda e qualquer intenção de ação (comprar carta, alocar exploit, submeter relatório, ativar habilidade de personagem) submetida pelo jogador é interceptada e processada por uma função de borda (*Edge Function*) isolada que executa a seguinte esteira obrigatória de validação:

1. **Autenticação Estrita:** Validação de assinatura criptográfica e tempo de expiração do token JWT.
2. **Autorização de Contexto:** Verificação de posse da partida, identificador do jogador e validação de turno ativo.
3. **Verificação de Legalidade Mecânica:** Validação das regras do jogo (se o jogador possui ferramentas suficientes para a vulnerabilidade, se a carta está na mão, se o escopo do programa aceita a classe da carta).
4. **Rate Limiting e Detecção de Automação:** Limitação de requisições por segundo para inviabilizar o uso de bots ou exploits de concorrência.
5. **Geração Criptográfica de Estado:** Processamento de mutações de estado e cálculos de probabilidade via gerador de números aleatórios seguro (CSPRNG).
6. **Persistência Transacional Atômica:** Gravação do novo snapshot de estado no banco PostgreSQL em transação única (`ACID`).
7. **Difusão em Tempo Real:** Publicação do novo estado sanitizado para todos os participantes via WebSockets seguros.

14.3 Proteção e Privacidade de Dados (LGPD & GDPR Compliance)

A coleta de dados restringe-se ao estritamente necessário para a operação do jogo: identificador único, e-mail cadastrado, nome público de exibição, avatar e métricas estatísticas agregadas de gameplay. Nenhuma informação financeira ou de cartão de crédito trafega pelos servidores de jogo, sendo o processamento delegado inteiramente às plataformas nativas da Apple e Google.

14.4 Autenticação e Gestão de Sessões

- Tokens JWT com tempo de vida curto (15 minutos) combinados com rotação obrigatória de *Refresh Tokens* (validade de 7 dias).
- Suporte a autenticação em duas etapas (2FA) via TOTP (Time-Based One-Time Password) para proteção de contas competitivas.

- Bloqueio temporário progressivo de endereços IP após 5 tentativas consecutivas de autenticação incorretas.

14.5 Mecanismos Anti-Cheat e Integridade Competitiva

O servidor detém autoridade irrestrita sobre todos os elementos ocultos do jogo:

- **Ocultação Real de Mão e Decks:** O cliente mobile recebe apenas os dados das cartas que estão visíveis para si. O conteúdo do deck de compras e as cartas nas mãos dos adversários residem exclusivamente na memória do servidor, tornando nula a eficácia de ataques de inspeção de memória no dispositivo local.
- **Auditoria Determinística de Replays:** Todas as ações executadas em partidas competitivas ranqueadas são registradas sequencialmente em logs auditáveis. Sistemas analíticos validam se a sequência de decisões produz o mesmo resultado determinístico do servidor.
- **Deteção de Anomalias de Comportamento:** Algoritmos estatísticos monitoram tempos de resposta desumanos, padrões de vitória improváveis ou fluxos de submissão anômalos, sinalizando contas para auditoria manual e aplicação de banimentos por identificador de hardware (Hardware ID) e conta.

14.6 Segurança de Redes e Endpoints

- Comunicação restrita ao protocolo TLS 1.3 com aplicação de *Certificate Pinning* nos binários móveis de produção para mitigar ataques de Man-in-the-Middle (MitM).
- Validação estrutural rígida de todas as cargas úteis de dados de entrada utilizando schemas fortemente tipados com `Zod`.
- Imunidade a ataques de SQL Injection garantida pelo uso sistemático de consultas parametrizadas e políticas de isolamento Row-Level Security (RLS) no PostgreSQL.

14.7 Políticas de Isolamento no PostgreSQL (Row Level Security)

O isolamento de dados no banco é protegido por regras declarativas de RLS em nível de tabela, impedindo acessos cruzados mesmo em eventuais falhas de lógica da aplicação:

```
-- Exemplo de política de segurança estrita para inventário de cartas do jogador
ALTER TABLE card_inventory ENABLE ROW LEVEL SECURITY;

CREATE POLICY "Usuários só podem visualizar seu próprio inventário"
ON card_inventory FOR SELECT
USING (auth.uid() = user_id);

CREATE POLICY "Apenas funções do servidor podem modificar cartas"
ON card_inventory FOR ALL
USING (auth.jwt() ->> 'role' = 'service_role');
```

14.8 Criptografia e Geração de Aleatoriedade (CSPRNG)

O embaralhamento de cartas, a distribuição de drops diários e os sorteios de eventos utilizam obrigatoriamente geradores de números pseudoaleatórios criptograficamente seguros (`crypto.randomBytes()` no ambiente Deno Edge Functions). O uso da função não determinística `Math.random()` é expressamente proibido no pipeline de regras do jogo.

14.9 Monitoramento, Auditoria e Programa de Bug Bounty

- Trilhas de auditoria imutáveis com registros de eventos operando no padrão *append-only*.
- Integração com esteiras de CI/CD contendo scanners automatizados de dependências e análise estática de código (SAST) via `Snyk` e `npm audit`.
- Estabelecimento de um programa formal de **Vulnerability Disclosure Program (VDP)** com recompensas reais para a comunidade de segurança que identificar falhas nos endpoints e contratos de API do próprio jogo.

15. Arquitetura de Software e Stack Tecnológica

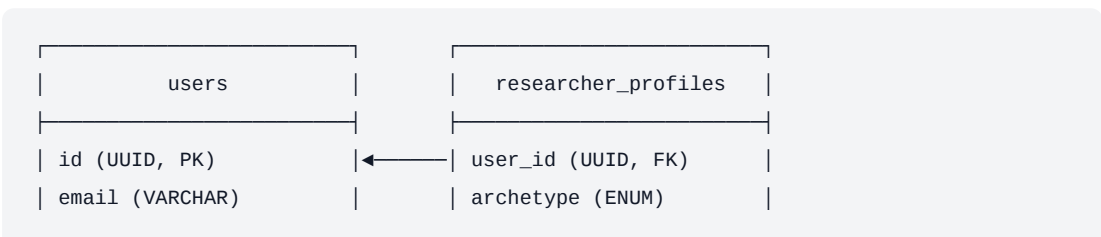
15.1 Frontend Mobile

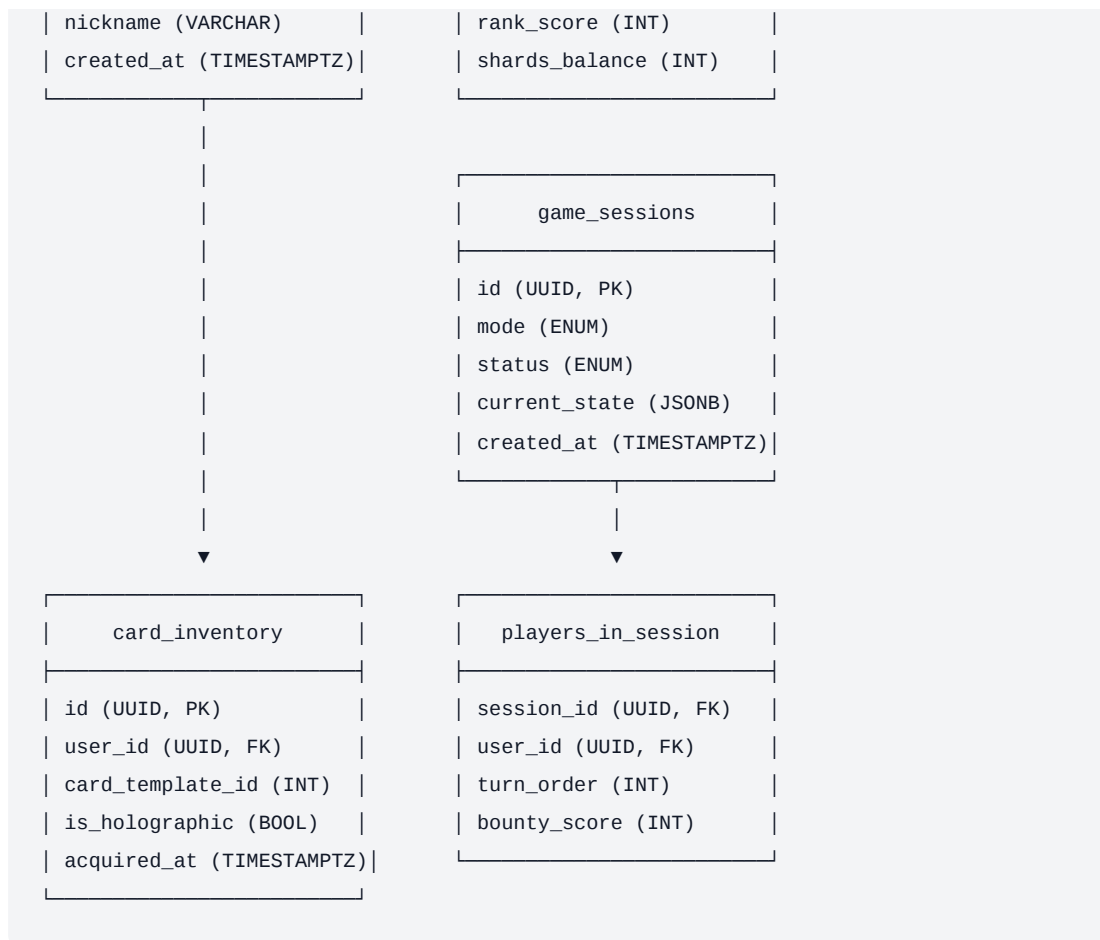
- **Framework:** React Native 0.74+ com Expo SDK 51+ (TypeScript configurado em modo estrito).
- **Gerenciamento de Estado:** `Zustand` atuando exclusivamente como cache reativo do estado recebido do backend.
- **Animações e Física de Cartas:** `react-native-reanimated 3.x` e `react-native-gesture-handler` para suporte a gestos fluidos a 60/120 FPS.
- **Renderização Gráfica Avançada:** `react-native-skia` para execução de shaders customizados de holografia e iluminação.
- **Roteamento e Navegação:** `Expo Router` baseado em arquitetura de arquivos.

15.2 Backend e Infraestrutura em Nuvem

- **BaaS Central:** `Supabase` (PostgreSQL 15+, Auth, Realtime Engine, Edge Functions rodando sobre runtime Deno).
- **Protocolos de Comunicação:** HTTPS / REST para chamadas estruturadas e WebSockets seguros (WSS) para difusão de eventos síncronos de mesa.
- **Armazenamento de Ativos:** Supabase Storage com distribuição global via CDN para artes de cartas, skins e áudios.

15.3 Modelo Estrutural de Dados (PostgreSQL Schema)





16. Estratégia de Testes, QA e Calibração

16.1 Matriz de Testes Automatizados

A confiabilidade do software é sustentada por uma pirâmide de testes abrangente:

- **Testes Unitários:** Cobertura de 100% das regras mecânicas de jogo, matrizes de cálculo de CVSS, condições de ativação de cartas e balanceamento de custos.
- **Testes de Integração:** Validação ponta a ponta dos fluxos de autenticação, transações de compra de cosméticos, criação de partidas assíncronas e sincronização WebSockets.
- **Simulações Estatísticas de Monte Carlo:** Execução automatizada de mais de 100.000 partidas simuladas por inteligência artificial a cada atualização de cartas para identificar combinações degeneradas e garantir que a taxa de vitórias (*win rate*) de qualquer arquétipo permaneça estritamente entre 45% e 55%.
- **Testes de Segurança Ofensiva:** Varreduras dinâmicas de segurança em ambiente de homologação cobrindo todos os requisitos do guia OWASP Mobile Application Security Verification Standard (MASVS).

16.2 Matriz de Dispositivos de Teste Homologados

Fabricante / Modelo	Sistema Operacional	Tamanho / Resolução	Foco de Validação
Apple iPhone SE (3ª Gen)	iOS 15.0	4.7" (1334 x 750)	Densidade de UI em telas compactas
Apple iPhone 15 Pro Max	iOS 17.0+	6.7" (2796 x 1290)	Performance de Shaders e ProMotion 120Hz
Apple iPad Air (5ª Gen)	iPadOS 16.0+	10.9" (2360 x 1640)	Adaptação responsiva de mesa expandida
Samsung Galaxy S24 Ultra	Android 14 (OneUI 6)	6.8" (3120 x 1440)	Renderização Skia em altas densidades DPI
Xiaomi Redmi Note 11	Android 11 (MIUI)	6.43" (2400 x 1080)	Otimização de memória RAM em specs de entrada
Google Pixel 8	Android 14 Stock	6.2" (2400 x 1080)	Conformidade com padrões nativos do SO

17. Estratégia de Lançamento e Go-To-Market

17.1 Posicionamento nas Lojas de Aplicativos (ASO)

- **Ícone do Aplicativo:** Tipografia de alto contraste com o logotipo **PWND!** estilizado sobre fundo escuro minimalista e cursor de terminal fosforescente pulsante.
- **Trailer Promocional:** Foco em ritmo dinâmico de 30 segundos, sem narradores convencionais: mãos reais manipulando a interface tátil, desencadeando combos de exploits rápidos até a interrupção caótica pelo alerta audiovisual de *PATCH DEPLOYED!*.
- **Galeria de Capturas de Tela:** Destaque para as artes conceituais das cartas, diagramação da mesa de jogo e certificações fictícias de relatórios de vulnerabilidade.

17.2 Estratégia de Aquisição por Segmento

- **Comunidade Especializada de Segurança:** Publicações técnicas em redes sociais profissionais desconstruindo vulnerabilidades reais por meio das cartas do jogo; engajamento em conferências de segurança (DefCon, Black Hat, Roadsec) com distribuição de baralhos físicos promocionais contendo códigos QR para itens cosméticos no jogo.
- **Público Geral de Jogadores Mobile:** Campanhas em plataformas de vídeos curtos (TikTok, YouTube Shorts) destacando momentos cômicos de jogadores sendo surpreendidos por cartas de evento em disputas multijogador.

17.3 Estratégia de Soft Launch

Lançamento preliminar direcionado aos mercados de Brasil e Portugal por um período de 6 semanas para validação de métricas de retenção (D1, D7, D30), balanceamento econômico de fragmentos e estabilidade dos clusters de WebSockets em ambiente de produção real.

18. Roadmap de Evolução do Produto

++		
	ROADMAP DE DESENVOLVIMENTO	
++		
	[v1.0] LANÇAMENTO OFICIAL	
	- 80 Cartas de Lançamento, 6 Arquétipos, 4 Modos de Jogo	
	(Solo 20 Missões, Async MP, Real-time PvP, Daily Bug Hunt)	
	- Localização: pt-BR, en-US, es-ES (Sem Guild Mode no lançamento)	
++		
	[v1.1] TELEMETRIA & CAMPANHA CAPÍTULO 2 (Mês 1)	
	- Chapter 2: "HEXACORP Strikes Back" (+20 Missões, total 40)	
	- Balanceamento via telemetria, 5 novas Tool Cards, melhorias de QoL	
++		
	[v1.2] TEMPORADA 1: "OWASP TOP 10 CHALLENGE" (Mês 2)	
	- 5 Novos Programas Corporativos, Localização em ja-JP/de-DE/fr-FR	
++		
	[v1.5] EXPANSION PACK 1 & GUILDS (Mês 3)	
	- Expansion Pack 1: +40 Novas Vulnerability Cards (total 120 cartas)	
	- Novo Researcher Archetype (7º), MODO GUILDAS, Modo Torneio	
++		
	[v2.0] TEMPORADA 2: "LOG4SHELL SEASON" (Mês 6)	
	- Expansion Pack 2: +27 Novas Cartas (total 147 – Acervo Completo!)	
	- Modo Espectador, Compartilhamento de Replays	
	- Localização em zh-CN, ko-KR, it-IT, ru-RU	
++		
	[v3.0] ECOSSISTEMA EXPANDIDO (Mês 12)	
	- Board game físico (Stretch Goal), API pública para cartas da	
	comunidade, Editor de Programas Corporativos Customizados	
++		

19. Apêndices

19.1 Glossário Técnico e Educacional

- **SQL Injection (SQLi):** Inserção maliciosa de comandos SQL em campos de formulário para manipulação indevida de bases de dados relacionais.
- **Cross-Site Scripting (XSS):** Injeção de scripts maliciosos em páginas web legítimas, executados no navegador de outros usuários.

- **Server-Side Request Forgery (SSRF):** Falha que induz o servidor a executar requisições em nome do atacante contra redes internas ou recursos protegidos.
- **Insecure Direct Object Reference (IDOR):** Falha de controle de acesso onde a aplicação expõe referências diretas a objetos internos sem checagem de autorização.
- **Broken Object Level Authorization (BOLA):** Variante moderna de IDOR crítica em APIs web, permitindo acesso não autorizado a recursos manipulando identificadores em requisições.
- **Remote Code Execution (RCE):** A mais severa das falhas, permitindo a execução arbitrária de comandos do sistema operacional no servidor alvo.
- **CVSS (Common Vulnerability Scoring System):** Padrão aberto da indústria para quantificar a gravidade e o impacto de vulnerabilidades de software em uma escala de 0.0 a 10.0.

19.2 Matriz de Distribuição das 80 Cartas de Lançamento

Classe de Vulnerabilidade	Common	Uncommon	Rare	Epic	Legendary	Total v1.0
Injection (SQLi, XXE, SSTI, OS Cmd)	6	4	3	2	1	16
Broken Access Control (IDOR, BOLA)	5	4	3	1	1	14
Cross-Site Scripting (XSS)	5	4	2	1	0	12
Authentication & Session Flaws	4	3	2	1	0	10
SSRF / CSRF	3	2	2	1	0	8
Business Logic Errors	3	2	2	1	0	8
Cryptographic Failures	2	2	1	1	0	6
Legendary / Multi-Stage Exploits	0	1	1	1	3	6

Classe de Vulnerabilidade	Common	Uncommon	Rare	Epic	Legendary	Total v1.0
Total de Cartas no Lançamento	28	22	16	9	5	80

Nota: As 67 cartas remanescentes que completam o acervo de 147 cartas serão adicionadas via Expansion Pack 1 (+40 cartas na v1.5) e Expansion Pack 2 (+27 cartas na v2.0).

19.3 Referências de Design e Ludologia

- *Wingspan* (Stonemaier Games) — Referência para construção de motores de recursos graduais e integração orgânica entre tema e regras.
- *Exploding Kittens* (Adan Hargrave, Matthew Inman) — Referência para gestão de tensão probabilística em decks de compra e humor visual.
- *OWASP Top 10 & API Security Top 10* (OWASP Foundation) — Base taxonômica formal para as classes de vulnerabilidades e ferramentas do jogo.
- *CVSS v3.1 Specification* (FIRST.org) — Base matemática para calibragem das escalas de severidade e premiações monetárias do sistema.

Documento elaborado em 31 de agosto de 2026. As informações contidas são de responsabilidade do solicitante.